

# **SIMATS ENGINEERING**

## **ASSESSMENT TOOL 3**

**COURSE NAME: Ethical Hacking**

**COURSE CODE: ITA14**

---

### **COURSE OUTCOME COVERED**

**CO2:** Foot printing Tools : Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

*Assessment Tool Weightage: 30%*

**Duration: 90 min**

**Total Marks: 50**

---

### **Scenario-Based Assessment**

#### **Annexure A**

Code of Conduct:

I KALPANA J(192521038)(Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

KALPANA J

## **Topic 1: Footprinting Tools – Conducting Competitive Intelligence**

### **Q1. (L3 – Apply) – 15 Marks**

A cybersecurity consultant has been assigned to perform a passive security assessment for a company named ABC Technologies. The consultant must collect publicly available information without directly interacting with the company's servers.

**Task:** Apply suitable footprinting tools to identify the company's:

- domain registration details,
- employee email addresses,
- technology stack,
- and publicly exposed subdomains.

Explain how each selected tool helps in conducting competitive intelligence.

## **Topic 2: DNS Zone Transfers**

### **Q2. (L3 – Apply) – 15 Marks**

During an authorized penetration test, a security analyst suspects that the target organization's DNS server is misconfigured and may allow unauthorized DNS zone transfers.

**Task:** Apply the appropriate DNS command or tool to verify whether zone transfers are permitted. If the transfer succeeds, explain how the retrieved DNS records can be used to identify internal hosts, mail servers, and subdomains during reconnaissance.

## **Topic 3: Introduction to Social Engineering – Social Engineering Attacks and Countermeasures**

### **Q3. (L3 – Apply) – 20 Marks**

Employees of an organization receive an email claiming to be from the IT department, asking them to verify their login credentials through a provided link because of an urgent security update.

Task: Identify the type of social engineering attack and apply suitable countermeasures that employees should follow before responding to the email. Explain how these actions help prevent credential theft.

---

## Q1. Footprinting Tools – Competitive Intelligence

### Aim

To collect publicly available information about **ABC Technologies** without directly interacting with its servers.

Since **ABC Technologies** is a placeholder, use the **authorized domain provided by your faculty/lab**. I'll write it as:

example.com

Replace **example.com** with your authorized lab domain.

### 1. theHarvester – Emails and subdomains

Check installation:

theHarvester -h

Run a passive

search:

```
theHarvester -d example.com -b crtsh
```

Depending on your Kali version, check available sources with:

```
theHarvester -h Save
```

the results:

```
theHarvester -d example.com -b crtsh -f footprinting_report
```

### **Record:**

- Email addresses
- Subdomains ● Hosts
- IP addresses

## **2. WHOIS – Domain Registration**

Install if necessary:

```
sudo apt install whois -y
```

Then:

```
whois example.com
```

Look for information such as:

- Registrar
- Domain creation/expiry information
- Nameservers
- Registration status

Some domains use privacy protection, so personal registrant information may not be available.

## **3. DNS Information Use:**

```
dig NS example.com Then:
```

```
dig MX example.com And:
```

```
dig A example.com
```

These can reveal nameservers, mail servers, and IP addresses.

#### 4. Technology Stack

If your lab provides **WhatWeb**, you can use it against an authorized target: whatweb

<https://example.com>

It may identify technologies such as:

- Web server
- CMS
- JavaScript frameworks
- Web technologies

For a strictly passive assessment, prefer publicly available sources rather than intrusive scanning.

#### Q1 Report Table

| Tool         | Information Obtained      | Purpose                         |
|--------------|---------------------------|---------------------------------|
| theHarvester | Emails, subdomains, hosts | Employee/domain reconnaissance  |
| WHOIS        | Registration information  | Domain intelligence             |
| dig          | DNS, NS, MX, A records    | DNS infrastructure mapping      |
| WhatWeb      | Web technologies          | Technology-stack identification |

## Competitive Intelligence Analysis

The collected information can help understand the organization's public infrastructure, technology choices, business contacts, and externally visible services. An attacker could potentially use this information to plan more targeted social-engineering or phishing attempts.

## Countermeasures

- Minimize unnecessary public information.
- Protect employee email addresses where possible.
- Regularly review public DNS records.
- Remove obsolete subdomains.
- Monitor public exposure of organizational information.
- Use privacy protection for domain-registration information where appropriate.

```
(kali@kali) [~/tesla-osint]
$ theHarvester -d tesla.com -b crtsh -f tesla_osint
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* THE HARVESTER *
*****
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*****

[*] Target: tesla.com
[*] Searching CRTsh.
[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] Hosts found: 327
*.cn.tesla.com
*.de.tesla.com
*.eu.logs.tesla.com
*.gf.tesla.com
*.logs.tesla.com
*.ma.logs.tesla.com
*.nv.tesla.com
*.ny.tesla.com
*.paloalto.tesla.com
*.powerhub.energy.tesla.com
*.tx.tesla.com
CitiiApiPdpProdV6.tesla.com
CitiiApiPdpProdV7.tesla.com
CitiiApiShpProdV6.tesla.com
CitiiApiSSLProdV7.tesla.com
akamai-apigateway-vehicleextinfofw-prdsvc-st.tesla.com
akamai-apigateway-vehicleextinfofw-stgsvc-st.tesla.com
ams13-gpgw1.tesla.com
apac-cppm.tesla.com
```

```
(kali@kali) [~/tesla-osint]
$ theHarvester -d tesla.com -b crtsh
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
* THE HARVESTER *
*****
* theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*****

[*] Target: tesla.com

An exception has occurred: 502, message='Attempt to decode JSON with unexpected mimetype: text/html', url='https://crt.sh/?q=%25.tesla.com&exclude=expired'
[*] Searching CRTsh.

[*] No IPs found.
[*] No emails found.
[*] No people found.
[*] No hosts found.
```

```
(kali@kali)~$ theHarvester -h
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
theHarvester
*****
theHarvester 4.8.2
* Coded by Christian Martorella
* Edge-Security Research
* cmartorella@edge-security.com
*****
usage: theHarvester [-h] -d DOMAIN [-l LIMIT] [-s START] [-p] [-s] [--screenshot SCREENSHOT] [-v] [-e DNS_SERVER] [-t] [-r [DNS_RESOLVE]] [-n] [-c] [-f FILENAME]
theHarvester is used to gather open source intelligence (OSINT) on a company or domain.
options:
  -h, --help            show this help message and exit
  -d, --domain DOMAIN    Company name or domain to search.
  -l, --limit LIMIT      Limit the number of search results, default=500.
  -s, --start START      Start with result number X, default=0.
  -p, --proxies          Use proxies for requests, enter proxies in proxies.yaml.
  -s, --shodan          Use Shodan to query discovered hosts.
  --screenshot SCREENSHOT Take screenshots of resolved domains specify output directory: --screenshot output_directory
  -v, --virtual-host      Verify host name via DNS resolution and search for virtual hosts.
  -e, --dns-server DNS_SERVER DNS server to use for lookup.
  -t, --take-over        Check for takeovers.
  -r, --dns-resolve [DNS_RESOLVE] Perform DNS resolution on subdomains with a resolver list or passed in resolvers, default False.
  -n, --dns-lookup        Enable DNS server lookup, default False.
  -c, --dns-brute         Perform a DNS brute force on the domain.
  -f, --filename FILENAME Save the results to an XML and JSON file.
  -w, --wordlist WORDLIST Specify a wordlist for API endpoint scanning.
  -a, --api-scan          Scan for API endpoints.
  -q, --quiet            Suppress missing API key warnings.
  -b, --source SOURCE     Baidu, bevigil, bing, bingapi, brave, bufferoverun, builtwith, censys, certspotter, criminalip, crtsh, dehashed, dnsdumpster, duckduckgo,
                        intel, leaklookup, netlas, onyphe, otx, pentesttools, projectdiscovery, rapiddns, rocketreach, securityscorecard, securitytrails,
                        urlscan, venacius, virustotal, whoisxml, yahoo, zoomeye
```

## Q2. DNS Zone Transfers

This should be done **only** against the DNS server provided for your authorized lab.

Assume:

Domain: lab.local

DNS Server: 192.168.1.20

Replace these with your actual lab values.

### Step 1 — Find the nameserver dig

NS lab.local

### Step 2 — Check the SOA record dig

SOA lab.local

### Step 3 — Test AXFR dig AXFR

lab.local @192.168.1.20

### If the transfer succeeds

You may see records such as:

lab.local. IN SOA ... lab.local.

IN NS ... www.lab.local.    IN A ...

mail.lab.local.    IN A ...

server.lab.local.    IN A ...

This demonstrates that the DNS server permits a zone transfer.

### **If it fails**

You may see:

Transfer failed. or:

status: REFUSED

This indicates that the server is restricting the transfer.

**Save the result** dig AXFR lab.local @192.168.1.20

> axfr\_result.txt

### **Analysis**

A successful unauthorized AXFR can expose:

- Internal hostnames
- IP addresses ● Mail servers ● Subdomains
- Nameservers
- Other DNS records

This information can help an attacker build a map of the organization's infrastructure during reconnaissance.

### **Security Measures**

- Restrict AXFR to authorized secondary DNS servers.
- Use TSIG authentication.
- Block unauthorized zone-transfer requests.
- Separate internal and external DNS. ● Monitor DNS logs.
- Regularly audit DNS configuration.



```

(kali@kali) [~]
$ dig @192.168.1.10 NS .
;; communications error to 192.168.1.10#53: timed out
;; communications error to 192.168.1.10#53: timed out
;; communications error to 192.168.1.10#53: timed out

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.1.10 NS .
; (1 server found)
;; global options: +cmd
;; no servers could be reached

```

```

kali@kali: ~
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali) [~]
$ dig example.com

; <<>> DiG 9.20.15-2-Debian <<>> example.com
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 40044
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;example.com.                IN      A
;; ANSWER SECTION:
example.com.                300     IN      A      172.66.147.243
example.com.                300     IN      A      104.20.23.154

;; Query time: 280 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Wed Aug 12 23:46:58 EDT 2026
;; MSG SIZE rcvd: 72

(kali@kali) [~]
$ dig NS example.com

; <<>> DiG 9.20.15-2-Debian <<>> NS example.com
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 34052
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;example.com.                IN      NS
;; ANSWER SECTION:
example.com.                21600   IN      NS      elliot.ns.cloudflare.com.
example.com.                21600   IN      NS      hera.ns.cloudflare.com.

;; Query time: 212 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Wed Aug 12 23:47:20 EDT 2026
;; MSG SIZE rcvd: 95

(kali@kali) [~]

```

```
Session Actions Edit View Help

(kali@kali)-[~]
$ dig -x 192.168.1.10

; <<>> DiG 9.20.15-2-Debian <<>> -x 192.168.1.10
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 56094
;; flags: qr rd ra; QUERY: 1, ANSWER: 0, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 512
;; QUESTION SECTION:
;10.1.168.192.in-addr.arpa.      IN      PTR

;; Query time: 12 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Wed Aug 12 23:50:10 EDT 2026
;; MSG SIZE rcvd: 54

(kali@kali)-[~]
$ dig @192.168.1.10 NS .
;; communications error to 192.168.1.10#53: timed out
;; communications error to 192.168.1.10#53: timed out
;; communications error to 192.168.1.10#53: timed out

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.1.10 NS .
; (1 server found)
;; global options: +cmd
;; no servers could be reached

(kali@kali)-[~]
$ nmap -Sv -p 53 192.168.1.10
Failed to resolve/decode supposed IPv4 source address "v": Name or service not known
QUITTING!

(kali@kali)-[~]
$ nmap -sV -p 53 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-12 23:52 EDT
Nmap scan report for 192.168.1.10
Host is up (0.00056s latency).

PORT      STATE      SERVICE VERSION
53/tcp    filtered  domain

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.06 seconds

(kali@kali)-[~]
```

### Q3. Social Engineering – Phishing Attack

#### Identify the Attack

The described attack is **phishing**, specifically a **credential-phishing/social-engineering attack**.

The attacker impersonates the IT department and creates a sense of urgency by claiming that the employee must verify their credentials because of a security update.

#### Attack Flow

Fake IT Email



Urgent Security Message



Employee Clicks Link



Fake Login Page



Credentials Stolen

## **Warning Signs**

Employees should look for:

- 1. Urgent language**

Example: "Verify immediately" or "Your account will be disabled."

- 2. Suspicious sender address**

The displayed name may say "IT Department" while the actual email address is different.

- 3. Suspicious URL**

The link may lead to a fake website.

- 4. Credential request**

Legitimate IT departments should not normally request passwords through email links.

- 5. Unexpected security notification**

Employees should independently verify unexpected account-security requests.

## **Countermeasures**

- 1. Verify the Sender**

Check the complete email address rather than trusting the display name.

- 2. Do Not Click Suspicious Links**

Instead of clicking the email link, manually open the organization's known official website or use an established internal portal.

- 3. Never Provide Passwords**

Employees should never enter passwords after following an unexpected email link.

- 4. Verify Through Another Channel**

Contact the IT department using a known phone number or official communication channel.

## 5. Report the Email

Use the organization's **Report Phishing** mechanism or forward the suspicious message to the security team according to company policy.

## 6. Use MFA

Multi-factor authentication provides additional protection if a password is accidentally exposed.

## 7. Email Security Controls Organizations

should use:

- Spam/phishing filters
- URL scanning
- Attachment scanning
- SPF
- DKIM
- DMARC

## How These Measures Prevent Credential Theft

The attacker depends on the employee trusting the fake message and entering credentials into a fraudulent website. Verifying the sender, avoiding suspicious links, using known official websites, and reporting the email can break this attack chain.

MFA provides another layer of protection because a stolen password alone may not be sufficient to access the account.

## Final Conclusion

Footprinting, DNS reconnaissance, and social engineering represent different stages of a potential attack.

Public Information



Reconnaissance



Identify People & Infrastructure



Social Engineering



## Potential Credential Theft

Therefore, organizations should minimize unnecessary information exposure, properly secure DNS infrastructure, train employees to recognize phishing, implement strong email-security controls, and use MFA to reduce the impact of compromised credentials.

nano social\_engineering\_analysis.txt Attack

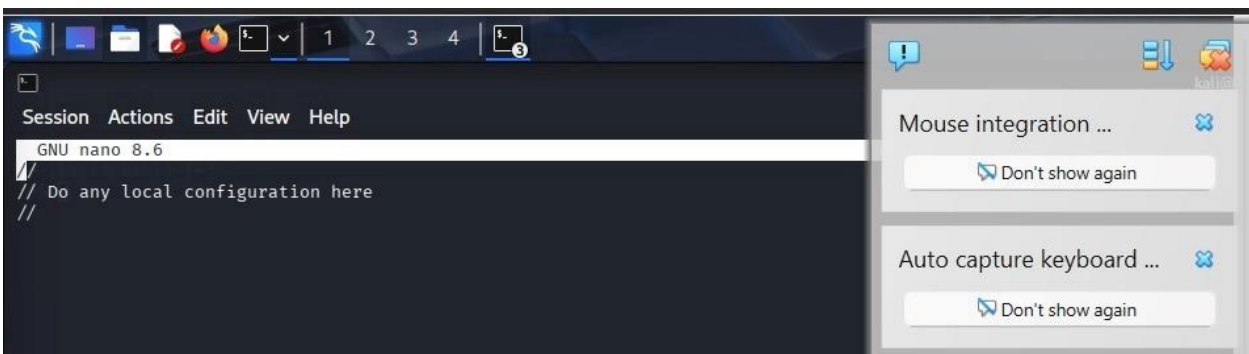
Type: Phishing / Credential Phishing

Warning Signs:

1. Urgent security request
2. Fake IT identity
3. Suspicious link
4. Request for login credentials

Countermeasures:

1. Verify the sender.
2. Do not click suspicious links.
3. Never provide passwords through email.
4. Contact IT using an official channel.
5. Report the email as phishing.
6. Use MFA.



## RUBRICS FOR CALCULATION

### Scenario Based Assessment

| Criteria                     | Weightage (%) | Level 4 (Exemplary)                                                       | Level 3 (Proficient)                               | Level 2 (Developing)                              | Level 1 (Beginning)                               |
|------------------------------|---------------|---------------------------------------------------------------------------|----------------------------------------------------|---------------------------------------------------|---------------------------------------------------|
| Understanding of Scenario    | 20%           | Demonstrates clear and complete understanding of the scenario and context | Shows good understanding with minor gaps           | Partial understanding; misses key aspects         | Misinterprets or fails to understand the scenario |
| Identification of Key Issues | 20%           | Accurately identifies all relevant issues and factors involved            | Identifies most key issues with minor omissions    | Identifies limited issues; some irrelevant points | Unable to identify key issues                     |
| Application of Concepts      | 25%           | Applies appropriate concepts effectively to address the scenario          | Applies concepts with minor errors                 | Limited or partially correct application          | Unable to apply relevant concepts                 |
| Decision Making              | 20%           | Makes well-reasoned, logical decisions with strong rationale              | Makes reasonable decisions with some justification | Makes weak decisions with limited justification   | No clear decisions made or rationale provided     |
| Clarity of Response          | 15%           | Response is clear, structured, and logically presented                    | Generally clear with minor issues                  | Somewhat unclear or poorly structured             | Disorganized and difficult to understand          |